

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 01

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
------------------------	----------------------	-------------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM1-058)

Scenario: A regional retailer plans to double its online revenue and enter two new markets. Security initiatives have historically been selected from technical wish lists.

Which action would BEST align the security program with the retailer's plan?

- A. Derive measurable security objectives from the expansion's critical processes and risks.
- B. Adopt the control catalog used by the retailer's largest competitor.
- C. Prioritize replacement of the oldest security technologies.
- D. Set program objectives after the new markets begin operating.

Question 2 (CISM1-059)

Scenario: A newly hired information security manager finds that business units treat security requests as optional because the program has no approved mandate.

What should the manager do FIRST?

- A. Publish detailed technical standards for all business units.
- B. Develop a program charter defining authority, scope, accountability, and sponsorship.
- C. Escalate every rejected security request to internal audit.
- D. Measure the number of requests rejected by each business unit.

Question 3 (CISM1-060)

Scenario: A manufacturer has approved initiatives for asset inventory, privileged-access governance, supplier monitoring, and analytics. Funding is available in phases, and the company will connect acquired plants to its network within six months.

What is the MOST appropriate basis for sequencing the roadmap?

- A. The order in which initiative owners submitted their proposals
- B. The relative purchase price of each supporting technology
- C. The amount of executive attention each initiative currently receives
- D. Risk reduction, capability dependencies, and the acquisition integration schedule

Question 4 (CISM1-061)

Scenario: A global group permits subsidiaries to operate independent technology teams. Several subsidiaries argue that the corporate security program should cover only shared infrastructure, although they process regulated customer information under the group brand.

How should the information security manager define program scope?

- A. Limit scope to systems funded by the corporate technology budget.
- B. Include only subsidiaries that have experienced a security event.
- C. Base scope on obligations, information risks, and shared accountability, allowing local implementation.
- D. Require corporate security to operate every control in every subsidiary.

Question 5 (CISM1-062)

What should PRIMARILY drive the resource model for an information security program?

- A. The current number of security employees
- B. The capabilities required to address business and risk priorities
- C. The organizational chart of the technology department
- D. The average staffing ratio reported by peer organizations

Question 6 (CISM1-063)

Scenario: A small healthcare services organization needs continuous monitoring but cannot recruit enough specialists. A qualified external provider can supply coverage, while business knowledge and risk decisions remain internal strengths.

Which sourcing approach is MOST appropriate?

- A. Use the provider under defined service requirements while retaining governance and risk ownership.
- B. Transfer the entire security program and all risk decisions to the provider.
- C. Postpone continuous monitoring until a fully internal team can be hired.
- D. Ask general technology staff to monitor alerts without role preparation.

Question 7 (CISM1-064)

Scenario: A logistics company must choose between expanding an existing identity capability and buying a heavily promoted replacement platform. Both could address access-control weaknesses, but migration would disrupt several customer-facing projects.

What analysis would BEST support the funding decision?

- A. A comparison of the number of features in each option
- B. A preference survey of the security engineering team
- C. A business case comparing risk reduction, lifecycle cost, integration, and delivery impact.
- D. A ranking of each vendor's market visibility

Question 8 (CISM1-065)

Scenario: A capability assessment shows strong technical operations but weak supplier-risk oversight and security architecture. Budget permits limited hiring and targeted development of current employees.

What should the manager do NEXT?

- A. Give all staff the same introductory security course.
- B. Recruit only for the competency with the highest market salary.
- C. Assign the missing work permanently to internal audit.
- D. Map competency gaps to hiring, development, and selective external support.

Question 9 (CISM1-066)

Who is normally accountable for determining an information asset's classification and business handling needs?

- A. The information owner
- B. The system administrator
- C. The internal auditor
- D. The storage service provider

Question 10 (CISM1-067)

Why should an information asset inventory include business purpose and ownership in addition to technical location?

- A. To let security administrators accept business risk
- B. To connect protection and lifecycle decisions to accountable business use
- C. To eliminate the need for information classification
- D. To prove that every asset has identical availability requirements

Question 11 (CISM1-068)

Scenario: Employees at a research company apply classification labels inconsistently because labels exist, but the policy does not explain how information may be stored, transmitted, shared, or destroyed.

What should the information security manager implement?

- A. A single handling rule for all information regardless of classification
- B. A requirement that the security team approve every file transfer
- C. Handling standards mapped to each classification and embedded in relevant workflows
- D. A report that counts how many classification labels employees select

Question 12 (CISM1-069)

Scenario: A financial cooperative discovers that former project teams retained duplicate customer datasets in collaboration spaces. The datasets have different access settings, and no owner can explain whether they remain necessary.

What should be done FIRST?

- A. Delete every duplicate immediately to reduce exposure.
- B. Identify owners and applicable retention requirements before disposal.
- C. Move all duplicates to lower-cost storage indefinitely.
- D. Allow workspace administrators to choose retention periods independently.

Question 13 (CISM1-070)

What is the PRIMARY purpose of adopting an information security framework for program development?

- A. To transfer security accountability to the framework publisher
- B. To mandate the same controls for every organization
- C. To certify that residual risk is acceptable
- D. To structure and assess security capabilities relevant to the organization.

Question 14 (CISM1-071)

Which approach BEST supports effective tailoring of an industry security framework?

- A. Map framework outcomes to organizational requirements, risks, and capabilities.
- B. Implement every referenced practice with equal priority.
- C. Remove practices that require cooperation from business units.
- D. Select only practices already supported by current tools.

Question 15 (CISM1-072)

Scenario: A software provider uses separate security frameworks for customer assurance, internal governance, and a regulated service. Teams duplicate testing because similar requirements use different language.

What should the manager do to improve integration?

- A. Replace all frameworks with the one containing the fewest requirements.
- B. Maintain separate controls and evidence for every framework reference.
- C. Map overlapping requirements to a common control set while preserving unique obligations.
- D. Ask customers to accept the regulated service's framework without comparison.

Question 16 (CISM1-073)

Which document normally states mandatory, specific requirements that support an information security policy?

- A. A guideline
- B. A procedure
- C. A program roadmap
- D. A standard

Question 17 (CISM1-074)

Why should procedures be traceable to approved policies and standards?

- A. To allow procedure authors to approve risk acceptance
- B. To ensure operational steps implement authorized requirements consistently
- C. To prevent procedures from ever changing between policy reviews
- D. To make every procedure applicable to every business process

Question 18 (CISM1-075)

Scenario: A revenue system cannot meet a new authentication standard before its peak season. The business owner requests a six-month exception and proposes additional monitoring.

What should the information security manager require before the exception is granted?

- A. Documented risk evaluation, accountable approval, compensating measures, an expiration date, and review conditions
- B. Permanent removal of the system from the scope of the standard
- C. Approval by the system administrator who will operate the monitoring
- D. A promise to replace the system during the next available budget cycle

Question 19 (CISM1-076)

Scenario: The remote-work policy permits personally owned devices, but an older data-handling standard prohibits regulated records on any device not owned by the company. A business process now relies on both documents.

What should the information security manager do FIRST?

- A. Allow process managers to choose whichever document is easier to follow.
- B. Treat the newer document as automatically overriding all older requirements.
- C. Suspend the entire remote-work program until every security document is rewritten.
- D. Reconcile the conflict with owners, then approve and communicate the revised hierarchy.

Question 20 (CISM1-077)

Scenario: A university is moving from institution-managed applications to a mix of cloud services and research partnerships. Project teams are making unrelated identity and data-protection decisions.

What should the security manager establish FIRST to create architectural coherence?

- A. A requirement that all projects buy one security product suite
- B. A detailed network configuration for every research partner
- C. Security capabilities aligned with target enterprise architecture and risk.
- D. An audit schedule covering every project before design begins

Question 21 (CISM1-078)

Scenario: An insurer has approved a digital-service strategy. Its proposed target security architecture assumes centralized identity, reliable asset data, and common logging, but these capabilities are fragmented today.

What is the MOST useful next step?

- A. Perform a current-to-target gap analysis that identifies capability dependencies, risks, and transition priorities.
- B. Approve the target state because its design is more modern than the current environment.
- C. Ask each project to close whichever architecture gap it encounters first.
- D. Replace the target architecture with a list of existing security products.

Question 22 (CISM1-079)

Scenario: A public services agency must make a citizen portal highly available and limit access to sensitive case records. Architects have produced diagrams, but reviewers cannot see how the design addresses those needs.

What should the information security manager request?

- A. More detailed diagrams showing every individual device
- B. Traceability from requirements to architecture decisions, capabilities, and controls.
- C. A statement that the architecture follows current industry trends
- D. Independent audit ownership of all architecture decisions

Question 23 (CISM1-080)

Scenario: A fast-growing media company has security architecture principles, but product teams routinely bypass them to meet release dates. Reviews occur only after deployment, when redesign is costly.

Which change would BEST improve solution governance?

- A. Require the security architect to approve every minor code change.
- B. Eliminate exceptions to ensure universal architectural consistency.
- C. Have internal audit design the security features for high-risk releases.
- D. Add early risk-tiered architecture checkpoints with documented exception paths.

Question 24 (CISM1-081)

Scenario: A hospital network can either replace several fragmented access services at once or transition in stages. A single cutover would reach the target state sooner but could disrupt clinical systems; a staged approach leaves some temporary inconsistency.

Which recommendation should the information security manager make?

- A. Choose the single cutover because target-state speed is the only architecture objective.
- B. Use a risk-assessed staged roadmap with dependencies, interim controls, success criteria, and rollback provisions.
- C. Retain the current architecture until every clinical system reaches end of life.
- D. Let each clinical unit select its own transition sequence without central coordination.

Question 25 (CISM1-082)

Which metric would BEST indicate the outcome of a privileged-access improvement program?

- A. Number of administrators invited to planning meetings
- B. Number of pages in the privileged-access standard
- C. Percentage of high-risk privileged accounts recertified on time.
- D. Total hours spent deploying the supporting tool

Question 26 (CISM1-083)

Scenario: A dashboard shows that critical vulnerability remediation performance has declined for three quarters. It reports only the enterprise-wide percentage completed within target.

What additional information would MOST improve management action?

- A. Trends segmented by accountable service, exposure, age, and constraints.
- B. The total number of vulnerability scanner signatures
- C. A comparison of dashboard colors used by peer organizations
- D. The number of times executives opened the dashboard

Question 27 (CISM1-084)

Scenario: A utility's security team proposes raising every assessed program capability to the highest maturity level. Executives ask whether the cost is justified.

How should the information security manager respond?

- A. Approve the proposal because maximum maturity always produces acceptable risk.
- B. Reject maturity assessments because they cannot support security decisions.
- C. Fund only the capabilities with the lowest current maturity scores.
- D. Set capability maturity targets based on risk, business need, outcomes, and cost.

Question 28 (CISM1-085)

Which input is **MOST** important when determining whether a proposed security control is appropriately designed?

- A. The control's popularity among peer organizations
- B. The age of the technology used to implement it
- C. The business risk and requirement the proposed control must address.
- D. The number of staff members available to test it

Question 29 (CISM1-086)

Scenario: A food distributor wants to protect warehouse handheld devices. A proposed control would require reauthentication every minute, interrupting safety-critical picking tasks.

What should the information security manager do?

- A. Approve the control because stricter authentication always reduces total risk.
- B. Evaluate alternative controls against the access risk, safety needs, and warehouse workflow.
- C. Let device users decide individually whether authentication is needed.
- D. Remove authentication requirements from all warehouse devices.

Question 30 (CISM1-087)

Scenario: A media archive encrypts files in storage and restricts administrator access. Its threat scenario also includes authorized users sending sensitive footage to unauthorized external recipients, but no control addresses that path.

What is the **BEST** management response?

- A. Reassess coverage against the full threat scenario and address outbound sharing.
- B. Accept the design because encryption addresses confidentiality in every use case.
- C. Increase the frequency of administrator access reviews only.
- D. Ask internal audit to become the owner of outbound-sharing controls.

Question 31 (CISM1-088)

Scenario: A global engineering firm can reduce a collaboration risk through a highly restrictive centralized control or through layered controls combining classification, conditional access, user prompts, and monitoring. Both meet the minimum requirement, but work patterns vary widely by region.

Which factor set should carry the **MOST** weight in the final selection?

- A. Which option has the greatest number of individual control components
- B. Which option can be deployed first regardless of user impact
- C. Comparative risk reduction, business usability, resilience, maintainability, and lifecycle cost
- D. The personal preference of the security technology lead

Question 32 (CISM1-089)

Scenario: A construction company has approved a new access-review control. The supporting tool is configured, but business reviewers have not been assigned and support teams have no operating procedures.

What should occur before the control is declared implemented?

- A. The vendor should confirm that the tool installation succeeded.
- B. Internal audit should assume responsibility for completing reviews.
- C. The project should report the percentage of its budget spent.
- D. Accountable reviewers, procedures, training, dependencies, and acceptance criteria should be confirmed.

Question 33 (CISM1-090)

Scenario: A travel company invites security to review new digital services only days before launch. Issues found at that stage repeatedly cause delays and expensive redesign.

Which action is MOST likely to improve outcomes?

- A. Perform more extensive security testing during the final launch meeting.
- B. Embed risk-tiered security requirements and review points from project initiation through release.
- C. Require the security team to become the business owner for every digital service.
- D. Approve launches automatically when project deadlines are fixed.

Question 34 (CISM1-091)

Scenario: A pharmaceutical company deployed a secure file-transfer process, but employees still use an older channel. Interviews show the new workflow adds several approvals and fails for common partner file sizes.

What should the information security manager do FIRST?

- A. Discipline every employee who used the former channel.
- B. Increase the number of messages stating that the new control is mandatory.
- C. Analyze adoption barriers, then correct the control and process design.
- D. Report the deployment as successful because the secure service is available.

Question 35 (CISM1-092)

Scenario: A payment company plans to activate a transaction control across all regions. The pilot reduced unauthorized activity, but one region's legacy workflow produced many false blocks and its support desk is not trained.

What is the BEST rollout decision?

- A. Proceed in ready regions and delay the remainder until readiness criteria are met.
- B. Deploy everywhere immediately because the pilot demonstrated some risk reduction.
- C. Cancel the control globally because one region is not ready.
- D. Let the tool vendor accept the business risk for the legacy workflow.

Question 36 (CISM1-093)

Scenario: A nonprofit has documented hundreds of controls but tests all of them on the same annual schedule. Several critical automated controls change frequently, while stable low-risk controls rarely change.

How should the testing program be improved?

- A. Stop testing stable controls permanently.
- B. Test only controls that previously failed.
- C. Use the same test procedure for every control to simplify reporting.
- D. Set testing scope and frequency according to risk, change, and prior results.

Question 37 (CISM1-094)

Scenario: Quarterly testing finds repeated failures in joiner and leaver access processing across three divisions. Each division has closed prior findings by correcting individual user records, but late removals continue.

What should the information security manager do NEXT?

- A. Analyze root causes, assign remediation owners, and track corrective action by risk.
- B. Close the new findings after the current user records are corrected.
- C. Increase the length of the access policy without changing the process.
- D. Transfer operation of the process to the testing team.

Question 38 (CISM1-095)

Which arrangement BEST preserves independent assurance over a security control?

- A. The control operator designs, performs, and approves the assurance review.
- B. An independent party evaluates appropriate evidence and reports results to relevant stakeholders.
- C. The control owner limits testing to evidence that already supports effectiveness.
- D. The security manager replaces all ongoing monitoring with an annual independent review.

Question 39 (CISM1-096)

Scenario: A lending platform reports that its sensitive-data control is effective because the governing standard was approved and the protection tool was installed. No operating samples, exception data, or outcome trends were reviewed.

How should the information security manager assess this conclusion?

- A. Accept it because approved documentation proves operating effectiveness.
- B. Accept it because installed technology proves that all relevant data is protected.
- C. Reject it and obtain evidence of sustained operation, exceptions, and outcomes.
- D. Defer all evaluation until a security incident involves the control.

Question 40 (CISM1-097)

What is the PRIMARY objective of an information security awareness program?

- A. To maximize the number of messages sent by the security team
- B. To ensure every employee receives identical technical training
- C. To transfer responsibility for security controls to employees
- D. To influence risk-reducing behavior and informed decisions in relevant work contexts

Question 41 (CISM1-098)

Scenario: A biotechnology firm gives all personnel the same annual security course. Developers continue to expose secrets in code repositories, and procurement staff omit required supplier-risk steps.

What is the MOST appropriate improvement?

- A. Increase the duration of the generic annual course for everyone.
- B. Add role-based learning tied to actual developer and procurement decisions.
- C. Limit future training to employees who have already made an error.
- D. Replace training with a policy acknowledgement form.

Question 42 (CISM1-099)

Scenario: An online marketplace reports 99 percent awareness-course completion, yet customer-support staff continue to bypass identity verification when callers create urgency.

Which measure would BEST evaluate whether the awareness intervention is working?

- A. Observed verification behavior during representative quality reviews by team.
- B. Number of slides in the annual course
- C. Percentage of staff who opened the course invitation
- D. Total budget allocated to awareness materials

Question 43 (CISM1-100)

Scenario: A professional services firm plans to use an external platform for confidential client work. Procurement wants to rely on a standard confidentiality clause and begin immediately.

What should the information security manager require?

- A. Acceptance of the clause as complete evidence of control effectiveness
- B. Transfer of information ownership to the platform provider
- C. Risk-based diligence, enforceable security obligations, monitoring, and exit provisions.
- D. A prohibition on all subcontractors regardless of the service design

Question 44 (CISM1-101)

Scenario: A payroll provider meets its service targets but depends on an undisclosed subcontractor for identity verification. The subcontractor processes employee data in a location not considered during onboarding.

What should the information security manager do FIRST?

- A. Ignore the dependency because the primary provider still meets availability targets.
- B. Assess the change against requirements and invoke applicable notification or approval rights.
- C. Contact the subcontractor directly and assume management of its controls.
- D. Wait until the next contract renewal to document the dependency.

Question 45 (CISM1-102)

Scenario: A subscription business will replace a provider that stores customer profiles and supports a critical workflow. The contract requires data return but does not define format, verified deletion, transition assistance, or access termination.

What is the BEST course of action before termination?

- A. Terminate immediately and determine data usability afterward.
- B. Retain the provider indefinitely because exit requirements are incomplete.
- C. Rely on the provider's general assurance that data is handled responsibly.
- D. Approve an exit plan covering data transfer, continuity, access revocation, and verified deletion.

Question 46 (CISM1-103)

Scenario: A security steering committee receives a monthly report containing thousands of alerts and patch counts. Members say they cannot identify which program outcomes are off track or what decisions they must make.

How should the report be redesigned?

- A. Show trends against outcomes and thresholds, business implications, decisions, and accountable owners.
- B. Add every raw alert so executives can conduct their own technical analysis.
- C. Remove negative trends until remediation plans are complete.
- D. Report only activities that the security team directly controls.

Question 47 (CISM1-104)

Scenario: A business unit has missed a critical control target for two reporting periods. Its remediation date now exceeds the approved risk threshold, and the program team lacks authority to accept the exposure.

What should the information security manager do NEXT?

- A. Escalate the exposure through the defined governance path with impact, evidence, accountability, and decision options.
- B. Extend the threshold so the dashboard returns to acceptable status.
- C. Accept the risk temporarily on behalf of the business owner.
- D. Omit the issue until the business unit agrees with the security team's assessment.

Question 48 (CISM1-105)

Scenario: A municipal security program is technically on schedule, but department leaders resist upcoming controls because they first learned about process changes shortly before implementation.

What would MOST improve stakeholder engagement?

- A. Limit program communications to completed technical milestones.
- B. Have the security team make operational tradeoffs without department input.
- C. Send the same detailed engineering report to every stakeholder.
- D. Engage leaders early on outcomes, impacts, roles, tradeoffs, and decisions.

Question 49 (CISM1-106)

Scenario: A publisher introduces a direct-to-consumer business model. Existing security procedures were designed for wholesale operations and do not address customer accounts, online payments, or new support workflows.

What should the information security manager do FIRST?

- A. Apply every wholesale control unchanged to the new model.
- B. Assess changed processes, information, obligations, and risks; then update the program.
- C. Wait for operating incidents to reveal which program changes are necessary.
- D. Create a separate security program with no connection to enterprise capabilities.

Question 50 (CISM1-107)

Scenario: An industrial design firm wants to use a new generative technology with confidential designs. Business teams have begun isolated pilots, while security has neither established requirements nor assessed how existing data controls apply.

What is the MOST appropriate program response?

- A. Ban the technology permanently because its risks are not fully known.
- B. Allow unrestricted pilots until a confirmed security failure occurs.
- C. Assess governed use cases, define risk-based guardrails, and conduct monitored pilots.
- D. Require each team to create its own security architecture and exception rules.

Answer Key

Domain III - Information Security Program

1 A	2 B	3 D	4 C	5 B
6 A	7 C	8 D	9 A	10 B
11 C	12 B	13 D	14 A	15 C
16 D	17 B	18 A	19 D	20 C
21 A	22 B	23 D	24 B	25 C
26 A	27 D	28 C	29 B	30 A
31 C	32 D	33 B	34 C	35 A
36 D	37 A	38 B	39 C	40 D
41 B	42 A	43 C	44 B	45 D
46 A	47 A	48 D	49 B	50 C

Detailed Explanations

Question 1 (CISM1-058)

Correct answer: A - Derive measurable security objectives from the expansion's critical processes and risks.

Objectives derived from critical business processes and their risks connect program work directly to the expansion. A competitor's controls may not fit the retailer, technology age alone does not establish priority, and waiting would leave the expansion without timely security direction.

Question 2 (CISM1-059)

Correct answer: B - Develop a program charter defining authority, scope, accountability, and sponsorship.

An approved charter establishes the mandate and sponsorship needed to develop and operate the program. Standards, escalation, and rejection metrics may follow, but none resolves the missing authority on which consistent participation depends.

Question 3 (CISM1-060)

Correct answer: D - Risk reduction, capability dependencies, and the acquisition integration schedule

A roadmap should sequence capabilities using risk reduction, dependencies, and business milestones, especially the approaching plant connections. Submission order, product cost, and temporary executive attention do not show which capabilities must precede others or protect the transformation.

Question 4 (CISM1-061)

Correct answer: C - Base scope on obligations, information risks, and shared accountability, allowing local implementation.

Scope should follow enterprise obligations and risk exposure, with clear accountability across the federated model. Funding boundaries and incident history can omit material exposure, while central operation of every control may be unnecessary and incompatible with local responsibility.

Question 5 (CISM1-062)

Correct answer: B - The capabilities required to address business and risk priorities

Required capabilities provide a risk- and business-based foundation for deciding skills, capacity, sourcing, and tools. Current headcount, reporting lines, and peer ratios can inform planning but cannot establish what this program actually needs.

Question 6 (CISM1-063)

Correct answer: A - Use the provider under defined service requirements while retaining governance and risk ownership.

A hybrid model addresses the capacity gap while preserving organizational governance, context, and risk ownership. Risk accountability cannot be outsourced, postponement leaves an identified need unmet, and unprepared staff do not provide a competent monitoring function.

Question 7 (CISM1-064)

Correct answer: C - A business case comparing risk reduction, lifecycle cost, integration, and delivery impact.

The decision should weigh expected risk reduction against full lifecycle cost, integration feasibility, and business delivery impact. Feature counts, team preferences, and vendor visibility may provide limited input but do not demonstrate enterprise value or affordability.

Question 8 (CISM1-065)

Correct answer: D - Map competency gaps to hiring, development, and selective external support.

A mapped competency plan uses several resource options to close specific gaps within budget. Generic training is not targeted, salary does not determine program priority, and internal audit must retain independence rather than operate missing program capabilities.

Question 9 (CISM1-066)

Correct answer: A - The information owner

The information owner is accountable for classification and business handling requirements. Administrators and providers act as custodians or operators, while internal audit independently evaluates whether responsibilities and controls are effective.

Question 10 (CISM1-067)

Correct answer: B - To connect protection and lifecycle decisions to accountable business use

Business purpose and ownership enable informed classification, protection, retention, and disposal decisions. Administrators do not inherit risk authority, an inventory does not replace classification, and asset requirements vary according to use and impact.

Question 11 (CISM1-068)

Correct answer: C - Handling standards mapped to each classification and embedded in relevant workflows

Classification becomes actionable when each level has clear handling requirements integrated into work processes. Uniform rules ignore differing risk, central approval is unlikely to scale, and label counts do not resolve the missing behavioral guidance.

Question 12 (CISM1-069)

Correct answer: B - Identify owners and applicable retention requirements before disposal.

Ownership and applicable retention requirements must be established before defensible disposition decisions are made. Immediate deletion could violate obligations, indefinite storage preserves unnecessary exposure, and local administrators lack the business authority to set retention independently.

Question 13 (CISM1-070)

Correct answer: D - To structure and assess security capabilities relevant to the organization.

A framework provides a structured reference for organizing, developing, and assessing capabilities. It does not transfer accountability, impose identical controls regardless of context, or determine whether the organization's residual risk is acceptable.

Question 14 (CISM1-071)

Correct answer: A - Map framework outcomes to organizational requirements, risks, and capabilities.

Mapping framework outcomes to the organization's own requirements, risks, obligations, and capabilities produces a defensible tailored program. Equal priority ignores context, while convenience-based exclusions can leave material risks and accountabilities unaddressed.

Question 15 (CISM1-072)

Correct answer: C - Map overlapping requirements to a common control set while preserving unique obligations.

A common control set reduces duplication and enables shared evidence while retaining traceability to unique obligations. Selecting the smallest framework can omit needs, separate implementations waste effort, and customer requirements cannot simply be assumed equivalent.

Question 16 (CISM1-073)

Correct answer: D - A standard

A standard sets mandatory, specific requirements supporting policy direction. A procedure describes how to perform work, a guideline offers recommended practices, and a roadmap sequences program initiatives rather than defining mandatory rules.

Question 17 (CISM1-074)

Correct answer: B - To ensure operational steps implement authorized requirements consistently

Traceability shows that operational steps implement authorized requirements and supports consistent maintenance. It does not grant risk authority, freeze procedures, or make them universal; procedures may vary by process while remaining aligned to governing documents.

Question 18 (CISM1-075)

Correct answer: A - Documented risk evaluation, accountable approval, compensating measures, an expiration date, and review conditions

A controlled exception must be risk-informed, explicitly approved by accountable parties, time-bound, and supported by appropriate compensating measures and review. Removing scope avoids governance, an operator is not necessarily the risk authority, and an unfunded promise lacks enforceable conditions.

Question 19 (CISM1-076)

Correct answer: D - Reconcile the conflict with owners, then approve and communicate the revised hierarchy.

Conflicting requirements require an authorized, risk-based resolution with the affected owners and clear communication. Local choice creates inconsistency, publication date alone does not establish authority, and suspending all remote work is disproportionate before the actual requirement is reconciled.

Question 20 (CISM1-077)

Correct answer: C - Security capabilities aligned with target enterprise architecture and risk.

Aligned principles and capability requirements translate enterprise direction and risk into consistent project guidance. Product uniformity is not the same as architectural coherence, partner configurations are an engineering concern, and audits provide assurance rather than the initial design direction.

Question 21 (CISM1-078)

Correct answer: A - Perform a current-to-target gap analysis that identifies capability dependencies, risks, and transition priorities.

A gap analysis exposes the capabilities and dependencies needed to move responsibly from current to target state and supports a risk-based transition. Modernity alone is not validation, project-by-project discovery creates fragmentation, and a product inventory does not define a target architecture.

Question 22 (CISM1-079)

Correct answer: B - Traceability from requirements to architecture decisions, capabilities, and controls.

Traceability demonstrates why architectural decisions and planned controls address the agency's stated availability and access needs. More component detail does not establish alignment, trends are not requirements, and auditors should assess rather than own architecture decisions.

Question 23 (CISM1-080)

Correct answer: D - Add early risk-tiered architecture checkpoints with documented exception paths.

Early, risk-tiered checkpoints make architecture governance timely and scalable, while a controlled exception path supports justified business needs. Reviewing every small change creates a bottleneck, forbidding all exceptions is inflexible, and internal audit should not design operational solutions.

Question 24 (CISM1-081)

Correct answer: B - Use a risk-assessed staged roadmap with dependencies, interim controls, success criteria, and rollback provisions.

A governed staged roadmap can balance resilience, delivery feasibility, and target-state progress while explicitly managing transitional risk. Speed alone neglects clinical impact, indefinite delay preserves weaknesses, and uncoordinated local decisions would perpetuate fragmentation.

Question 25 (CISM1-082)

Correct answer: C - Percentage of high-risk privileged accounts recertified on time.

Ownership and timely recertification measure whether the intended governance outcome is operating across high-risk accounts. Meetings, document length, and deployment hours are activity or effort measures that do not demonstrate effective access governance.

Question 26 (CISM1-083)

Correct answer: A - Trends segmented by accountable service, exposure, age, and constraints.

Segmented trends connect the declining outcome to accountable areas, exposure, persistence, and constraints so leaders can target action. Scanner content, display preferences, and dashboard views do not explain the performance gap or its risk significance.

Question 27 (CISM1-084)

Correct answer: D - Set capability maturity targets based on risk, business need, outcomes, and cost.

Target maturity should be economically and operationally appropriate for each capability, not uniformly maximal. Maximum maturity does not guarantee acceptable risk, maturity assessments can be useful, and a low score alone does not show that investment will materially improve business outcomes.

Question 28 (CISM1-085)

Correct answer: C - The business risk and requirement the proposed control must address.

Control design is appropriate when it addresses defined risk and requirements in the organization's operational and architectural context. Popularity, technology age, and tester capacity may influence implementation or assurance but do not establish design suitability.

Question 29 (CISM1-086)

Correct answer: B - Evaluate alternative controls against the access risk, safety needs, and warehouse workflow.

Control selection must balance risk reduction with safety and operational requirements, and alternative designs may achieve both. Maximum strictness can create new business risk, individual choice is inconsistent, and removing authentication abandons the access objective.

Question 30 (CISM1-087)

Correct answer: A - Reassess coverage against the full threat scenario and address outbound sharing.

The control set must be traced to the full risk scenario, including misuse through authorized sharing channels. Storage encryption and administrator reviews do not address that path, and internal audit should assess coverage rather than own the control.

Question 31 (CISM1-088)

Correct answer: C - Comparative risk reduction, business usability, resilience, maintainability, and lifecycle cost

A sound control strategy balances effective risk reduction with business fit, resilience, maintainability, and total cost across regions. Component count, deployment speed alone, and one specialist's preference do not provide a sufficient basis for an enterprise control decision.

Question 32 (CISM1-089)

Correct answer: D - Accountable reviewers, procedures, training, dependencies, and acceptance criteria should be confirmed.

Implementation includes people, process, ownership, and verified readiness, not merely installed technology. Vendor confirmation and budget use do not prove the control can operate, while internal audit must remain independent of routine control execution.

Question 33 (CISM1-090)

Correct answer: B - Embed risk-tiered security requirements and review points from project initiation through release.

Early, proportionate integration lets teams address requirements and risks when design changes are less costly. A larger last-minute review preserves the timing problem, security should not own the business service, and automatic approval would ignore unresolved exposure.

Question 34 (CISM1-091)

Correct answer: C - Analyze adoption barriers, then correct the control and process design.

The manager should address workflow and technical barriers that prevent the control from operating as intended, with owners accountable for risk during correction. Punishment or repeated messages do not fix unusable design, and availability alone is not evidence of adoption or effectiveness.

Question 35 (CISM1-092)

Correct answer: A - Proceed in ready regions and delay the remainder until readiness criteria are met.

A controlled, criteria-based rollout preserves demonstrated value while addressing the region-specific operational risk and readiness gap. Immediate deployment ignores customer impact, global cancellation discards a viable control, and the organization cannot transfer its business risk decision to the vendor.

Question 36 (CISM1-093)

Correct answer: D - Set testing scope and frequency according to risk, change, and prior results.

Risk-based testing directs assurance effort according to control significance, change rate, design, and performance history. Stable or previously successful controls still need proportionate evaluation, and a uniform procedure may not produce suitable evidence for different control types.

Question 37 (CISM1-094)

Correct answer: A - Analyze root causes, assign remediation owners, and track corrective action by risk.

Recurring failures show that record-level corrections are not addressing the underlying process weakness. Root-cause remediation with ownership and risk-based tracking supports sustained improvement; longer policy text does not fix operations, and testers should not assume control operation.

Question 38 (CISM1-095)

Correct answer: B - An independent party evaluates appropriate evidence and reports results to relevant stakeholders.

Organizational independence from control operation improves objectivity, provided the reviewer has access and a clear reporting path. Operator self-approval and selective evidence undermine assurance, while periodic independent review complements rather than replaces management's ongoing monitoring.

Question 39 (CISM1-096)

Correct answer: C - Reject it and obtain evidence of sustained operation, exceptions, and outcomes.

Approval and installation may support design or implementation, but they do not demonstrate complete coverage or sustained operation. Appropriate samples, exceptions, trends, and outcomes are needed; waiting for an incident would confuse failure evidence with proactive assurance.

Question 40 (CISM1-097)

Correct answer: D - To influence risk-reducing behavior and informed decisions in relevant work contexts

Awareness should improve decisions and behaviors that reduce relevant human and process risks. Message volume is only activity, role needs differ, and employee awareness does not transfer accountability away from control and business owners.

Question 41 (CISM1-098)

Correct answer: B - Add role-based learning tied to actual developer and procurement decisions.

Role-based, workflow-linked learning addresses the distinct decisions producing risk and can be reinforced when action is needed. A longer generic course remains poorly targeted, training only after errors is reactive, and acknowledgement does not establish practical competence.

Question 42 (CISM1-099)

Correct answer: A - Observed verification behavior during representative quality reviews by team.

Observed verification behavior measures the specific risk-reducing outcome and segmentation supports targeted reinforcement. Course size, invitation opens, and budget are inputs or activity indicators that do not show whether staff apply the required behavior.

Question 43 (CISM1-100)

Correct answer: C - Risk-based diligence, enforceable security obligations, monitoring, and exit provisions.

Third-party governance spans selection, contracting, operation, monitoring, and exit, with requirements proportionate to the client information risk. A clause alone is insufficient, ownership remains with the organization, and an absolute subcontractor ban may be unnecessary if dependencies are identified and governed.

Question 44 (CISM1-101)

Correct answer: B - Assess the change against requirements and invoke applicable notification or approval rights.

The undisclosed processing dependency is a material service change requiring timely assessment and use of established contractual governance. Availability alone does not cover confidentiality or location needs, direct control management bypasses the primary provider's accountability, and waiting prolongs unassessed exposure.

Question 45 (CISM1-102)

Correct answer: D - Approve an exit plan covering data transfer, continuity, access revocation, and verified deletion.

A coordinated exit plan protects confidentiality, integrity, availability, and evidence needs during the transition. Immediate termination could disrupt service or strand data, indefinite retention avoids the decision, and general assurance does not establish verifiable completion.

Question 46 (CISM1-103)

Correct answer: A - Show trends against outcomes and thresholds, business implications, decisions, and accountable owners.

Executive reporting should connect program performance to agreed outcomes, risk significance, accountability, and decisions. Raw detail obscures priorities, withholding negative trends undermines oversight, and limiting scope to security-owned activity can hide enterprise dependencies.

Question 47 (CISM1-104)

Correct answer: A - Escalate the exposure through the defined governance path with impact, evidence, accountability, and decision options.

The breached threshold and missing decision authority require transparent escalation to the accountable governance level. Changing the threshold masks exposure, the security manager should not assume the owner's acceptance authority, and delaying reporting impairs timely oversight.

Question 48 (CISM1-105)

Correct answer: D - Engage leaders early on outcomes, impacts, roles, tradeoffs, and decisions.

Early, continuing engagement gives affected leaders visibility and a meaningful role in operational decisions and accountability. Milestone-only communication is late, unilateral tradeoffs weaken ownership, and a single engineering report will not meet different stakeholder needs.

Question 49 (CISM1-106)

Correct answer: B - Assess changed processes, information, obligations, and risks; then update the program.

The new model changes business processes and exposure, so the program should reassess requirements and adapt capabilities in a coordinated roadmap. Reusing controls without analysis may misfit the risk, incidents are a poor prerequisite, and a disconnected program would duplicate governance and capabilities.

Question 50 (CISM1-107)

Correct answer: C - Assess governed use cases, define risk-based guardrails, and conduct monitored pilots.

Governed experimentation supports business learning while establishing proportionate safeguards, evidence, and a path to mature program capabilities. A permanent ban may sacrifice value without analysis, unrestricted use leaves confidential data exposed, and team-specific governance fragments accountability and architecture.